

ACTIVIDAD 11

LAB: FILE PATH TRAVERSAL

*Validation of
Start of Path*

FABIOLA CALVILLO GALVÁN 182455

MTRO. SERVANDO LÓPEZ CONTRERAS

LABORATORIO:

FILE PATH TRAVERSAL

VALIDATION OF START OF PATH

Introducción

Nombre del laboratorio: File Path Traversal: Validation of Start of Path

Nivel del Laboratorio: Practitioner

Tipo de explotación: Path Traversal (Directory Traversal) mediante evasión de una validación del inicio de la ruta. La aplicación intenta comprobar que la ruta proporcionada por el usuario comience con el directorio esperado, pero esta validación puede ser manipulada utilizando una ruta que conserve el directorio permitido al inicio y posteriormente utilice **../** para salir de él.

Objetivo del laboratorio

El objetivo es explotar la vulnerabilidad de Path Traversal en la funcionalidad de visualización de imágenes de productos para conseguir acceder a un archivo fuera del directorio autorizado. En concreto, se debe recuperar el contenido del archivo: **/etc/passwd**. La aplicación transmite la ruta completa del archivo mediante un parámetro de la petición y comprueba que la ruta comience con el directorio esperado.

Explicación Técnica de la Explotación

La aplicación utiliza una validación similar a: **¿La ruta proporcionada comienza con el directorio permitido?** Por ejemplo, podría esperar una ruta como: **/var/www/images/36.jpg**

El problema es que comprobar únicamente el comienzo de la cadena no garantiza que el archivo se encuentre realmente dentro de ese directorio.

Se puede construir una ruta que inicialmente comience con el directorio permitido: **/var/www/images/../../etc/passwd**

La ruta comienza con: **/var/www/images/**, por lo que puede superar la validación inicial. Sin embargo, cuando el sistema resuelve la ruta, las secuencias: **../** hacen que se retroceda en la estructura de directorios:

```
/var/www/images/
../
/var/www/
../
/var/
../
/
```

Finalmente se llega a: **/etc/passwd**

El problema principal es que la aplicación valida la cadena de texto, pero no verifica correctamente la ruta normalizada que finalmente utilizará el sistema.

Explotación

Primero se identifica una petición relacionada con la imagen del producto, por ejemplo: **GET /image?filename=/var/www/images/36.jpg HTTP/2**. El parámetro vulnerable sería: **filename**.

En lugar del archivo original, se introduce una ruta que comienza con el directorio esperado y posteriormente utiliza Path Traversal: **/var/www/images/../../../../etc/passwd**

La petición quedaría conceptualmente:

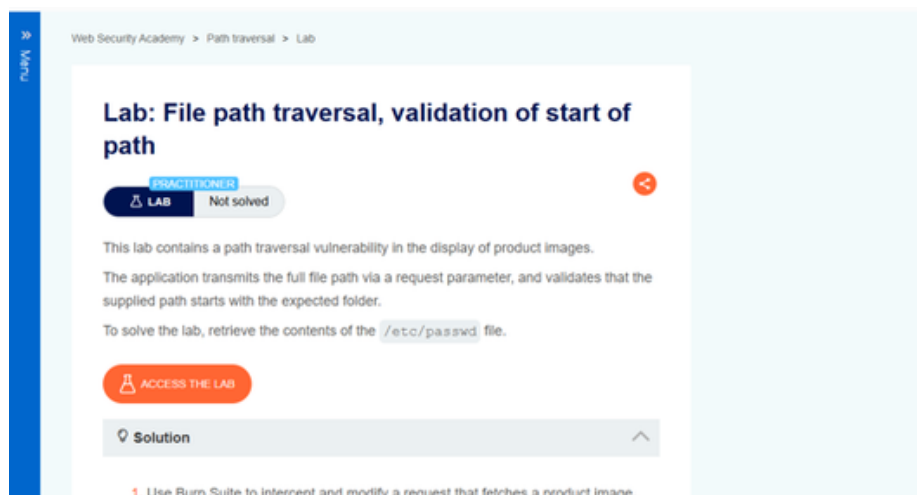
GET /image?filename=/var/www/images/../../../../etc/passwd HTTP/2

El servidor valida inicialmente que la ruta comienza con: **/var/www/images/** pero posteriormente resuelve los **../**, terminando en: **/etc/passwd**.

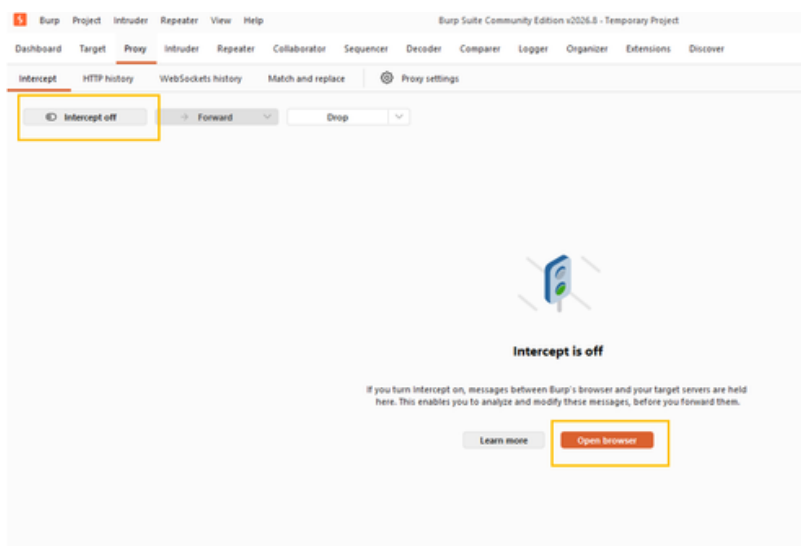
Si la explotación es correcta, la respuesta HTTP mostrará el contenido del archivo **/etc/passwd**.

Procedimiento paso a paso

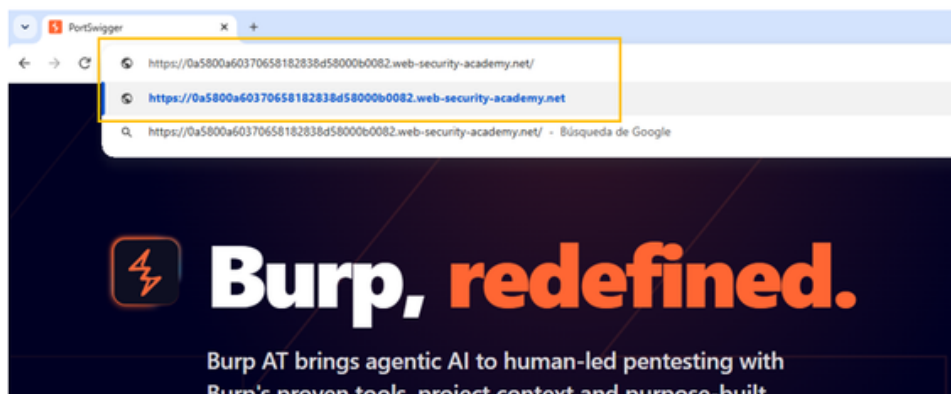
Primero deberemos acceder a la página en donde podremos ingresar a nuestra práctica de laboratorio.



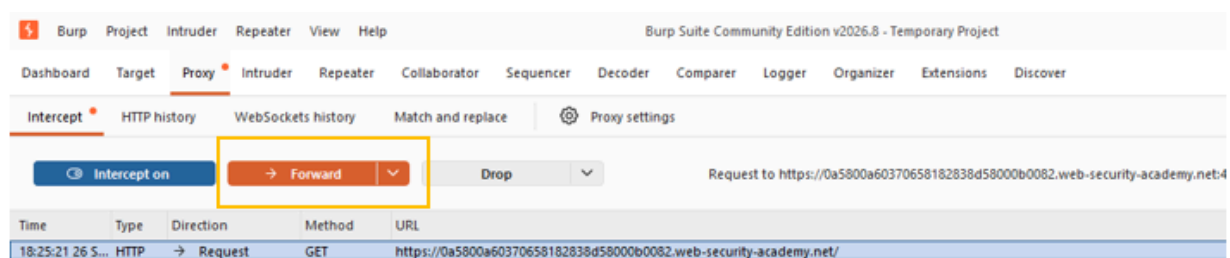
Después de haber ingresado, debemos iniciar BurpSuite, que es en donde estaremos realizando la práctica. Continuando, una vez iniciado BurpSuite, debemos de movernos a la pestaña de Proxy. En donde tendremos que Encender el Interceptador y Abrir Navegador para poder iniciar nuestra práctica.



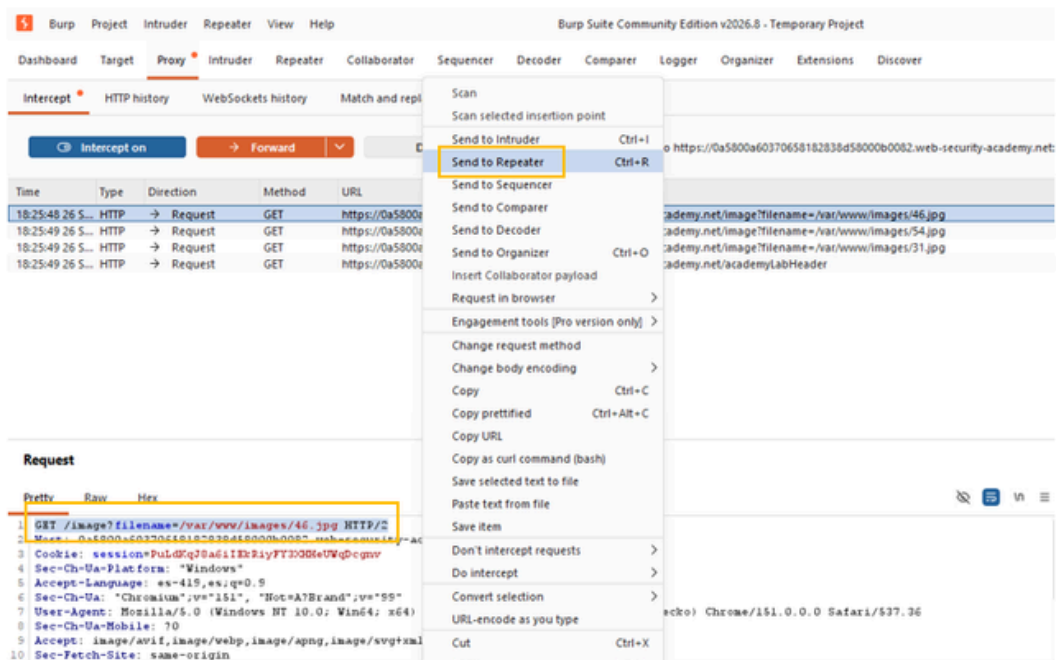
Una vez abierto el navegador deberemos ingresar el enlace de la práctica, para poder ingresar a la página..



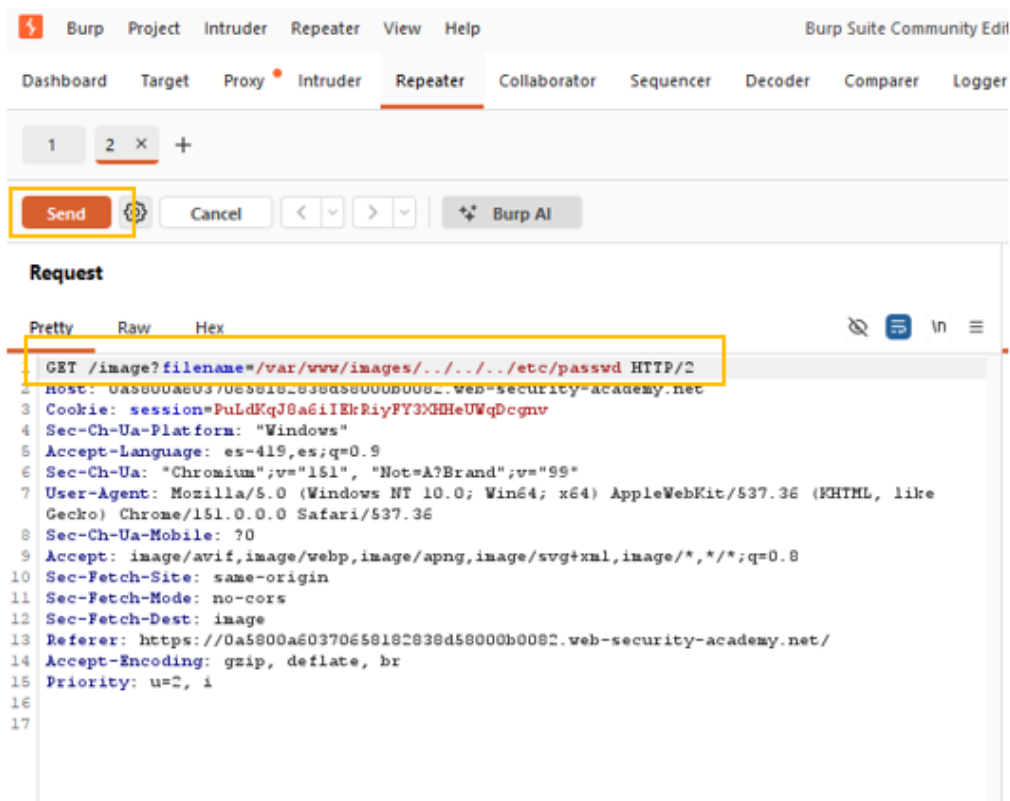
Ya que ingresamos el enlace, nos moveremos a la ventana de BurpSuite, en donde veremos todas las acciones que se llegan hacer para que la página cargue. Para poder realizar la práctica debemos de dar clic en **Forward** hasta que en las peticiones nos aparezca la ruta de una imagen.



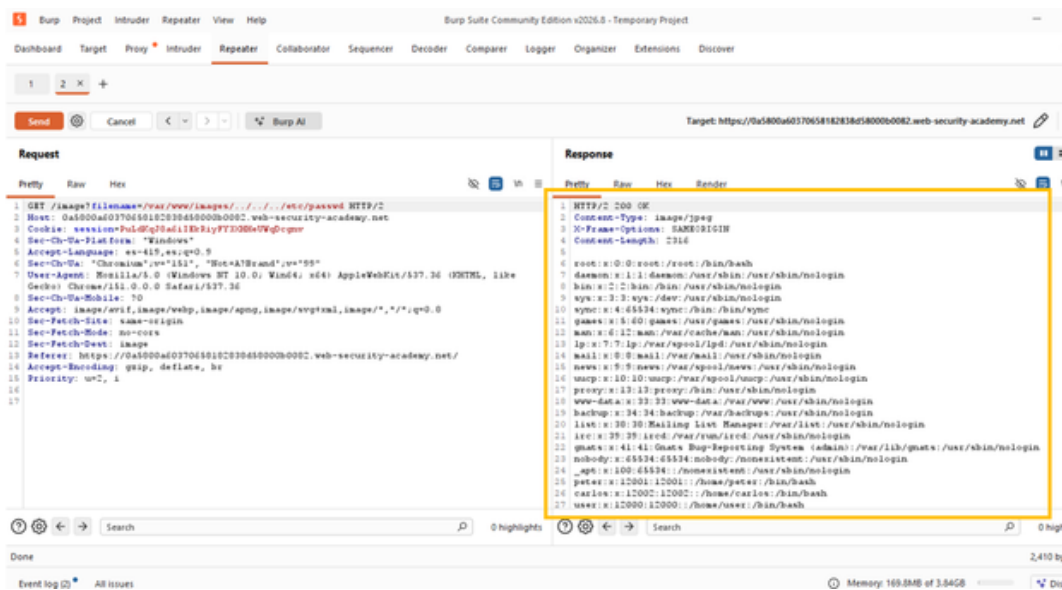
Ya que ubicamos el endpoint, debemos seleccionarlo y dar clic derecho sobre lo seleccionado, para que se nos despliegue un menú en el cual se mostrarán diferentes opciones, nosotros en este caso seleccionaremos la opción de **Send to Repeater** (Enviar al Repetidor).



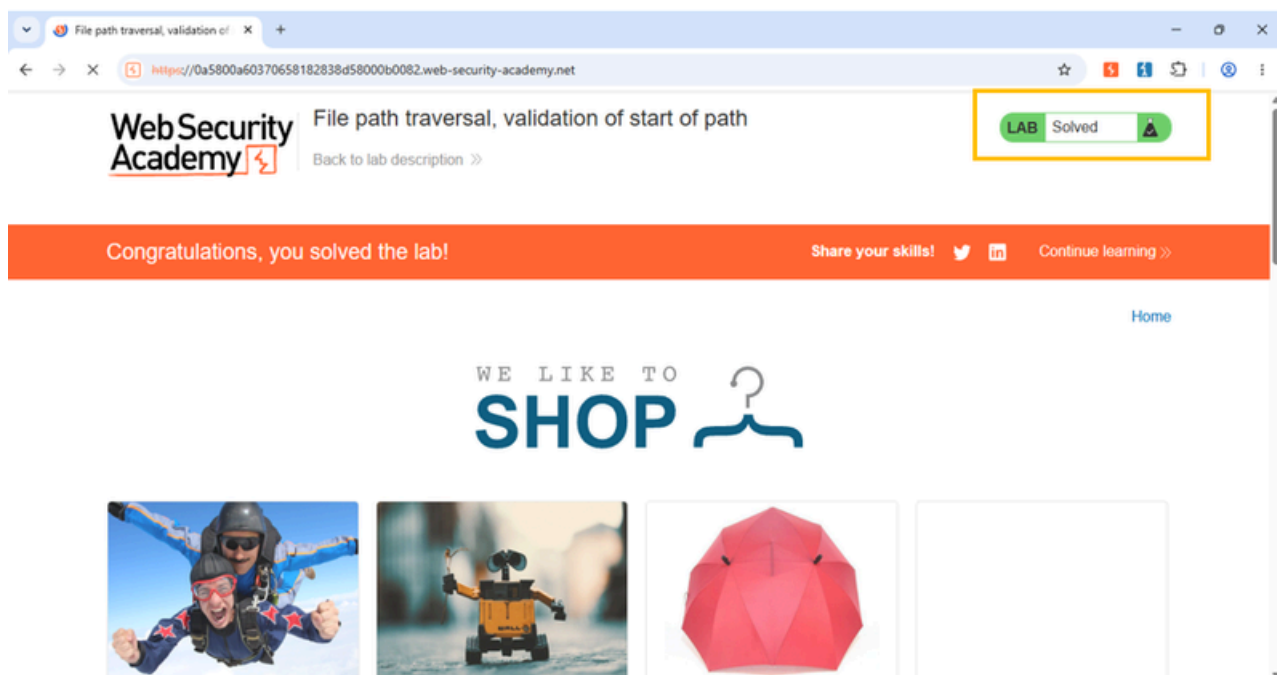
Después de haber mandado esta intrucción al repetidor, debemos movernos a la pestaña de **Repeater**, en donde cambiaremos la ruta para que se pueda abrir la imagen. Nosotros, cambiaremos esa ruta a la siguiente: **GET /image?filename=/var/www/images/../../../../etc/passwd HTTP/2**. Esto apra poder visualizar lo que se encuentra en ese directorio, pero para eso debemos dar clic en **Send**.



Una vez que dimos clic en **Send**, se deberá mostrar el contenido del directorio en el apartado de **Response**.



Al poder observar esta información, esto nos indica que nuestra práctica está terminada de manera satisfactoria. Pero podemos confirmar esto al irnos a la página de la práctica, en donde se deberá ver que ya la resolvimos.



Explicación del Payload

El payload tiene esta estructura: **[RUTA_PERMITIDA]/../../etc/passwd** Por ejemplo:
/var/www/images/../../etc/passwd

Cada elemento tiene una función:

- **/var/www/images/** es el directorio que la aplicación espera encontrar al inicio.
- **..** representa el directorio padre.
- **/../** permite subir un nivel en la estructura de directorios.
- **../../..** permite retroceder varios niveles.
- **/etc/passwd** es el archivo objetivo.

La característica importante de este ataque es que la cadena comienza de forma válida, pero posteriormente contiene instrucciones para abandonar el directorio autorizado.

Mitigación Recomendada

La aplicación no debería limitarse a comprobar que la cadena empiece con un directorio determinado.

Se recomienda:

1. Normalizar/canonicalizar la ruta antes de validarla.
2. Comprobar que la ruta final normalizada se encuentre realmente dentro del directorio permitido.
3. No permitir que el usuario proporcione directamente rutas del sistema.
4. Utilizar identificadores de archivos en lugar de rutas proporcionadas por el usuario.
5. Aplicar una lista blanca de archivos o extensiones permitidas.
6. Ejecutar la aplicación con los mínimos permisos necesarios, evitando que pueda leer archivos sensibles.